

RAPPORT D'ANALYSE DE VULNÉRABILITÉS

TP1 — Analyse Statique de Firmware avec Binwalk

Contexte	Formation Sécurité IoT / Firmware — Jour 2
Périmètre	TP1 : Analyse Statique avec Binwalk
Type d'analyse	Analyse statique (black-box)
Cible	Firmware routeur Wi-Fi (image binaire)
Date	1 avril 2026
Classification	CONFIDENTIEL — Usage pédagogique

1. Contexte et Objectifs

Ce rapport constitue le rendu officiel du Travail Pratique n°1 (TP1) de la formation « Analyse et Émulation de Firmware Wi-Fi — Jour 2 ». L'objectif de ce TP est de mettre en œuvre une analyse statique complète d'une image firmware de routeur Wi-Fi afin d'identifier et de documenter les vulnérabilités de sécurité présentes dans le logiciel embarqué.

L'analyse statique consiste à examiner le firmware sans l'exécuter, en extrayant son contenu et en inspectant les fichiers, binaires, scripts et configurations qui le composent. Cette approche permet de détecter des failles structurelles, des informations sensibles exposées et des configurations dangereuses avant même tout déploiement.

Objectifs du TP1

- Extraire le contenu d'une image firmware de routeur Wi-Fi à l'aide de Binwalk
- Identifier le système de fichiers et les composants architecturaux (MIPS, ARM, etc.)
- Analyser les fichiers critiques : `/etc/passwd`, `/etc/shadow`, scripts init, interface web
- Rechercher des informations sensibles exposées (mots de passe, credentials hardcodés)
- Documenter chaque vulnérabilité avec son niveau de criticité et des recommandations de correction

2. Méthodologie d'Analyse

La méthodologie appliquée suit une approche en quatre phases successives, conformément aux bonnes pratiques de l'analyse statique de firmware embarqué.

Phase 1 — Préparation de l'environnement

Installation de Binwalk dans un environnement virtualisé et isolé du réseau de production :

```
sudo apt update && sudo apt install binwalk
```

Binwalk détecte automatiquement les signatures de formats connus (SquashFS, CramFS, archives compressées, en-têtes ELF) embarqués dans l'image binaire.

Phase 2 — Analyse initiale du firmware

L'analyse initiale identifie la structure du firmware : offsets, types de données, systèmes de compression.

```
binwalk firmware.bin
```

Phase 3 — Extraction récursive

L'extraction récursive décompresse tous les composants imbriqués pour reconstituer l'arborescence complète du système de fichiers :

```
cd ~/IoT/formation-Jour2
rm -rf _firmware.bin.extracted
binwalk -Me firmware.bin
```

L'option -M active le mode récursif, -e déclenche l'extraction automatique de tous les composants détectés.

Phase 4 — Exploration des fichiers critiques

Une fois le système de fichiers reconstitué, l'analyse se concentre sur les répertoires à fort risque :

```
cd _firmware.bin.extracted/
find . -type f -exec file {} \; | grep ELF
```

- /etc/passwd et /etc/shadow — gestion des comptes utilisateurs
- /etc/init.d/ — scripts de démarrage des services
- /www/ — interface web d'administration
- Binaires ELF — exécutables et démons réseau

3. Tableau Récapitulatif des Vulnérabilités

L'analyse statique du firmware a permis d'identifier 6 vulnérabilités de sécurité réparties sur trois niveaux de sévérité. Ces failles sont représentatives des problèmes couramment rencontrés dans les firmwares de routeurs grand public et constituent un risque significatif si le dispositif est déployé sans correction préalable.

2 vulnérabilités CRITIQUES permettant potentiellement l'obtention d'un accès root complet au système via extraction et cracking de credentials.

2 vulnérabilités ÉLEVÉES concernant l'exposition de services non sécurisés (Telnet) et des permissions excessives sur les scripts système.

2 vulnérabilités MOYENNES portant sur l'interface web et l'utilisation de fonctions C dangereuses susceptibles de mener à des débordements mémoire.

Synthèse de l'ensemble des vulnérabilités identifiées lors de l'analyse statique du TP1, classées par ordre décroissant de sévérité.

ID	Titre	Sévérité	CVSS	Composant
VUL-01	Fichiers /etc/passwd et /etc/shadow accessibles	CRITIQUE	9.1	/etc/passwd, /etc/shadow
VUL-02	Credentials hardcodés en clair dans les binaires	CRITIQUE	8.8	ingssvcd, httpd (ELF)
VUL-03	Service Telnet non sécurisé actif par défaut	ÉLEVÉE	7.5	/bin/telnetd
VUL-04	Scripts init avec permissions excessives	ÉLEVÉE	7.2	/etc/init.d/*
VUL-05	Interface web exposant des informations sensibles	MOYENNE	5.3	/www/
VUL-06	Fonctions C dangereuses sans protection mémoire	MOYENNE	5.0	Binaires ELF